



Chapter 2 – Email Analysis, Phishing, Email Authentication & IOC Analysis



What is Email Analysis?

Email Analysis is the process of investigating emails to determine whether they are:

- ✓ Legitimate Emails
- ✓ Spam Emails
- ✓ Phishing Emails
- ✓ Spoofed Emails
- ✓ Malware Delivery Emails

Since most cyber attacks begin through **Social Engineering**, email analysis is one of the most important tasks of a SOC Analyst.



In real-world organizations, more than 90% of successful cyber attacks start with a phishing email.



Real-Life Example

Imagine you receive an email:

Subject: Urgent! Your Bank Account Will Be Blocked

The email asks you to click a link and enter your banking credentials.

A SOC Analyst must determine:

- Who sent the email?
 - Is the sender genuine?
 - Is the link safe?
 - Does the attachment contain malware?
 - Is this a phishing attempt?
-



Components Checked During Email Analysis

SOC Analysts investigate multiple parts of an email:

1 Header Analysis

Email headers contain technical information about the email.

Analysts check:

- ✓ Sender Email Address
 - ✓ Sender Domain
 - ✓ Sender IP Address
 - ✓ Return Path
 - ✓ Message ID
 - ✓ SPF Status
 - ✓ DKIM Status
 - ✓ DMARC Status
 - ✓ Email Routing Path
-

2 Email Body Analysis

The email body contains the actual content.

SOC Analysts check:



Grammar and Spelling Mistakes

Many phishing emails contain:

- Incorrect grammar
- Broken sentences
- Unusual wording



Name Verification

Check whether:

- Correct recipient name is used
- Generic greetings are used

Examples:

✗ Dear Customer

✗ Dear User

✓ Dear John Smith

3 Subject Analysis

The subject line is extremely important.

Attackers often create urgency.

Examples:

🚨 Your Account Will Be Suspended

🚨 Urgent Action Required

🚨 Password Expiring Today

🚨 Claim Your Prize

🚨 Verify Your Account Now

Such subjects are common indicators of phishing.

4 Attachment Analysis

SOC Analysts investigate attachments such as:

- PDF Files
- Word Documents
- Excel Files
- ZIP Files
- EXE Files
- JavaScript Files

Dangerous File Types

⚠️ .exe

⚠️ .js

⚠️ .vbs

⚠️ .scr

⚠️ .bat

These files may directly execute malicious code.



Macro Enabled Documents

What are Macros?

A Macro is a small program or script inside:

- Microsoft Word
- Microsoft Excel
- Microsoft PowerPoint

Macros are designed to automate repetitive tasks.

Legitimate Use of Macros

Examples:

- Auto-formatting reports
 - Automatic calculations
 - Invoice generation
-

How Attackers Abuse Macros

Suppose you receive:

📎 Invoice.docm

Inside the document, the attacker hides a malicious VBA macro.

When opened, Microsoft Office displays:

"Enable Content"

or

"Do you want to view this content?"

If the victim clicks **Enable Macros**, the script executes.

The macro may:

- ✓ Download Malware
 - ✓ Create Backdoors
 - ✓ Install Ransomware
 - ✓ Steal Passwords
 - ✓ Open Reverse Shell Connections
-



What is Phishing?

Definition

Phishing is a cyber attack where attackers impersonate trusted organizations to steal:

- Passwords
 - OTPs
 - Credit Card Details
 - Banking Information
 - Personal Information
-

Signs of a Phishing Email

1. Urgency or Fear

Examples:

-  Your account will be locked.
-  Payment failed.
-  Action required immediately.

Attackers create panic so users act without thinking.

2. Grammar Mistakes

Examples:

-  Dear Customer Your account blocked now immediately.

Poor language is often a red flag.

3. Suspicious Attachments

Examples:

-  invoice.exe
 -  payment.zip
 -  document.scr
-

4. Credential Requests

Examples:

- Login Credentials
- Passwords
- OTPs
- Credit Card Information

Legitimate organizations rarely request such information through email.

5. Too-Good-To-Be-True Offers

Examples:

-  You won \$10,000
-  Claim your free iPhone
-  Get a free vacation package

These are common phishing tactics.



How Personal Data Helps Phishing Attacks

Truecaller Example

Applications such as Truecaller may collect:

- Contact Names
- Phone Numbers
- SMS Information (if permission granted)

If attackers gain access to such information, they can create highly personalized phishing campaigns.

Example

Instead of:

 Dear User

Attackers may send:

 Hello Rahul, claim your RummyCircle bonus now.

Personalized attacks are much more successful.

Security Tip

Never grant:

- SMS Access
- Contact Access
- Call Log Access

to applications that do not genuinely require those permissions.



Understanding Email Headers

What is an Email Header?

An Email Header contains hidden technical metadata about an email.

It shows:

- Email Origin
- Mail Servers Used
- Authentication Results
- Sender Information

Think of it as a travel history of the email.



How to View Email Headers

Gmail

1. Open Email
2. Click : (Three Dots)
3. Select **Show Original**

You will see:

- Message ID
- Creation Time
- Delivery Time
- Recipient
- Subject

- SPF
 - DKIM
 - DMARC
 - Return Path
-

Important Email Header Fields

1 From

Shows who claims to have sent the email.

 Easily spoofed.

2 Return Path

The actual email address used for bounce-back messages.

Example

From:

support@paypal.com

Return Path:

attacker@fake-domain.ru

 Huge Red Flag

The sender is clearly not PayPal.

Why Return Path Matters

In legitimate emails:

 From Domain = Return Path Domain

If they do not match:

 Possible Email Spoofing

 Possible Phishing

Received Field

The most important header field.

Shows:

- Email route
- Servers crossed
- Original sending server

The bottom-most Received entry often reveals the true sender IP.

Message-ID

Every email has a unique identifier.

It can reveal:

- Sending Domain
 - Mail Server Information
-

Reply-To

Used when recipients click Reply.

Example:

From:

support@bank.com

Reply-To:

attacker@gmail.com

 Phishing Attempt

Authentication Results

Contains:

- SPF Result
 - DKIM Result
 - DMARC Result
-

What is an MX Record?

Definition

MX (Mail Exchange) Record is a DNS record that tells the Internet: Which mail server is responsible for receiving emails for a domain.

Real-Life Example

Suppose someone sends mail to:

admin@example.com

The sending server asks DNS:

Which server handles email for example.com?

DNS replies:

example.com MX 10 mail1.example.com

example.com MX 20 mail2.example.com

The email is delivered to the specified mail server.

Why MX Records Matter

Without MX Records:

 Emails cannot be received.

Benefits:

 Email Routing

- ✓ Backup Mail Servers
 - ✓ Email Authentication Support
 - ✓ SPF/DKIM/DMARC Functionality
-

SPF (Sender Policy Framework)

What is SPF?

SPF verifies:

Is this mail server allowed to send emails for this domain?

How SPF Works

Step 1

Domain owner purchases a domain.

Example:

hmbyte.com

Step 2

Domain owner configures DNS.

Step 3

An A Record is created.

Example:

hmbyte.com → 10.10.10.10

The A Record maps a domain to an IP address.

Step 4

MX Records are configured.

Example:

mail.hmbyte.com

The DNS now knows which server handles email.

Step 5

SPF Record is added.

Example:

v=spf1 include:_spf.google.com -all

Step 6

When an email arrives:

Receiving mail server asks DNS:

Is this IP authorized to send mail for this domain?

Results

✓ SPF Pass

Authorized sender.

⚠ SPF SoftFail

Suspicious.

✗ SPF Fail

Unauthorized sender.

Usually delivered to Spam or rejected.



DKIM (DomainKeys Identified Mail)

What is DKIM?

DKIM uses cryptography to ensure:

- ✓ Email was sent by the claimed domain
- ✓ Email content was not modified during transmission

How DKIM Works

Step 1

Sender Mail Server signs email using:



Private Key

Step 2

Public Key is published in DNS.

Step 3

Receiving server retrieves the public key.

Step 4

Signature verification occurs.

Results



DKIM Pass

Email is authentic.



DKIM Fail

Email may be altered or spoofed.

Real-Life Analogy

Think of DKIM as a wax seal on an envelope.

If the seal is broken:

⚠ Someone tampered with the letter.



DMARC (Domain-based Message Authentication, Reporting & Conformance)

What is DMARC?

DMARC works on top of:

- SPF
- DKIM

It determines:

What should happen if authentication fails?

DMARC Actions

p=none

Only monitor.

p=quarantine

Move email to Spam.

p=reject

Completely reject the email.

Example

v=DMARC1;
p=quarantine;
rua=mailto:dmarc-reports@domain.com

How DMARC Works

SPF DKIM DMARC Result

Pass Pass Pass ✓

Pass Fail Usually Fail ⚠

Fail Pass Depends on Alignment ⚠

Fail Fail Reject ✗

🎯 SPF vs DKIM vs DMARC

Technology Purpose

SPF Verify sender IP

DKIM Verify email integrity

DMARC Decide action based on SPF/DKIM

Together they prevent:

- ✓ Email Spoofing
 - ✓ Business Email Compromise (BEC)
 - ✓ Phishing Attacks
-

🔧 What are Exploits?

An Exploit is code that takes advantage of a software vulnerability.

Types of Exploits

Local Exploit

Requires access to the machine.

Example:

Privilege Escalation.

Remote Exploit

Executed over a network.

Example:

Malicious Website Attack.

Zero-Day Exploit

Targets an unknown vulnerability.

No patch exists.



Macros vs Exploits

Feature	Macros	Exploits
Runs In	Office Files	Any Vulnerable Software
User Action Needed	Usually Yes	Sometimes No
Purpose	Run Scripts	Exploit Vulnerabilities



URL Analysis

Before clicking any link:

Hover over it.

Check:

- Domain Name

- Redirects
 - Reputation
-

Common Fake Domains

- ✗ paypal.com
- ✗ micros0ft.com
- ✗ faceb00k.com

These are known as Typosquatting Domains.

IOC (Indicators of Compromise)

Definition

IOCs are pieces of evidence left behind by attackers.

SOC Analysts collect them during investigations.

Types of IOCs

Email-Based IOCs

- Sender Email
 - Sender Domain
 - Return Path
 - URLs
 - Attachments
 - Subject Lines
-

File-Based IOCs

- File Names
- File Hashes
- Metadata
- Digital Signatures

Hash Types

- MD5
- SHA1
- SHA256

Hash = Unique Fingerprint of a File

Network-Based IOCs

- IP Addresses
 - Domains
 - Hostnames
 - URLs
 - DNS Requests
 - Ports
-

Host-Based IOCs

- Registry Changes
 - New Services
 - Scheduled Tasks
 - Suspicious Processes
 - New User Accounts
-

Behavioral IOCs

- Unusual Logins
 - Data Exfiltration
 - Privilege Escalation
 - Impossible Travel Logins
-

Important SOC Tools

IP Reputation Analysis

AbuseIPDB

Shows:

- ISP
- ASN
- Hostname
- Country
- City
- Abuse Reports

If a reported malicious IP sent an email:

 IOC Found

Cisco Talos Intelligence

Used for:

- Sender Reputation
 - Email Reputation
 - Threat History
-

AlienVault OTX

Used in Threat Intelligence.

Provides:

- IP Details
 - Threat Campaigns
 - Malware Information
 - Threat Pulses
-

IPVoid

Provides:

- Whois Lookup
 - IP Reputation
 - CIDR Information
 - Traceroute
 - MX Records
-

URL Reputation Analysis Tools

VirusTotal

Checks:

- Malware
 - Phishing
 - Blacklists
 - Domain Reputation
-

URLScan.io

Shows:

- Redirect Chain
 - Screenshot
 - Scripts
 - Contacted IPs
-

Google Safe Browsing

Checks whether Google has marked a website as:

- ⚠ Phishing
 - ⚠ Malware
 - ⚠ Unsafe
-



Attachment Analysis (SOC Process)

Never open suspicious attachments directly on your system.

Correct Procedure

1. Download Attachment
2. Do NOT Execute It
3. Open Inside VMware / Sandbox
4. Calculate Hash Value
5. Submit Hash to VirusTotal
6. Review:
 - File History
 - Registry Changes
 - Dropped Files
 - Network Connections

- Malware Detections

Interview Questions

Q1. What are the three main email authentication protocols?

- ✓ SPF
- ✓ DKIM
- ✓ DMARC

Q2. What does SPF verify?

SPF verifies whether the sender's IP address is authorized to send emails for a domain.

Q3. What does DKIM verify?

DKIM verifies email integrity and authenticity using digital signatures.

Q4. What does DMARC do?

DMARC decides whether emails should be accepted, quarantined, or rejected based on SPF and DKIM results.

Q5. What is an IOC?

An Indicator of Compromise (IOC) is evidence that suggests a system, network, or email may be involved in malicious activity.
